PROGRAMACIÓN MÓVIL · EXPOSICIÓN

De app vulnerable a app blindada

Almacenamiento inseguro y comunicación sin protección en Android, con demo en vivo

Oscar Gil · Jean Marthe

Plan de la exposición

Bloque	Habla	Tiempo
Contexto: amenazas, OWASP, MASVS y app de demo	Expositor A	3 min 45 s
Demo 1 · Almacenamiento: ataque y defensa	Expositor B	3 min 45 s
Demo 2 · Red: ataque y defensa	Expositor A	3 min 30 s
Biometría atada al Keystore	Expositor B	45 s
Checklist, límites y cierre	B, A y B	1 min 45 s

Total: unos 13 minutos y medio más preguntas. Quien explica habla; el otro maneja el teclado en la demo.

Un teléfono no es un entorno de confianza

En el dispositivo

Root, copias de seguridad o análisis dinámico permiten leer y alterar datos locales.

En la red

Sin protección, un atacante en la ruta puede leer y modificar el tráfico sin ser detectado.

En el binario

Un APK se puede decompilar a código Java: todo lo que lleva dentro es legible.

Idea guía: diseñar como si el atacante tuviera la app y el dispositivo en la mano.

Fuentes: OWASP MASTG-TEST-0338 · Android Developers (<application>) · jadx

OWASP Mobile Top 10 (2024): dónde cae la demo

M1 Uso inadecuado de credenciales · **Demo 1**	**M2** Seguridad insuficiente de la cadena de suministro
M3 Autenticación y autorización inseguras	**M4** Validación insuficiente de entradas y salidas
M5 Comunicación insegura · **Demo 2**	**M6** Controles de privacidad inadecuados
M7 Protecciones insuficientes del binario	**M8** Configuración de seguridad incorrecta · **Demo 2**
M9 Almacenamiento inseguro de datos · **Demo 1**	**M10** Criptografía insuficiente

Fuente: OWASP Mobile Top 10, lista 2024 · devguide.owasp.org y owasp.org

MASVS: del riesgo al control verificable

Top 10
Qué riesgos existen.

MASVS
Qué controles debe cumplir la app.

MASTG
Cómo se prueba cada control.

MASVS-STORAGE-1

La app almacena de forma segura los datos sensibles.

MASVS-STORAGE-2

La app evita fugas de datos sensibles.

MASVS-NETWORK-1

La app protege todo el tráfico de red según las mejores prácticas vigentes.

MASVS-NETWORK-2

La app fija la identidad (pinning) de los servidores bajo control del desarrollador.

Fuente: OWASP MASVS · mas.owasp.org/MASVS (enunciados parafraseados)

La demo: una app, dos versiones

Aspecto	Versión vulnerable	Versión segura
Token de sesión	SharedPreferences en texto plano	AES-GCM con clave del Android Keystore
Clave de API	Hardcodeada en el código	Sin secretos en el APK: el servidor emite el token
Tráfico de red	HTTP o CA de usuario aceptadas	Solo HTTPS con pinning de clave pública
Pantalla de saldo	Se abre sin verificación	Se abre tras BiometricPrompt

Stack: Kotlin · emulador Android · servidor local de pruebas · jadx · mitmproxy

DEMO 1 · ALMACENAMIENTO

El problema: datos sensibles en texto plano

SharedPreferences escribe un XML sin cifrar en el sandbox de la app.

El sandbox no frena a root, a las copias de seguridad ni al análisis dinámico.

Una clave hardcodeada viaja dentro del APK y se lee al decompilarlo.

DEBILIDADES CATALOGADAS (MASWE)

- 0001 Datos sin cifrar en almacenamiento privado
- 0003 Claves fuera del Keystore de la plataforma
- 0004 Datos sensibles hardcodeados en la app
- 0006 Datos sensibles no excluidos del backup

Fuentes: MASTG-TEST-0287 · MASTG-TEST-0338 · MASVS-STORAGE (mas.owasp.org)

DEMO 1 · EL ATAQUE

Leer token y clave de nuestra propia app

1. Iniciar sesión en la app vulnerable (emulador, build debug).
2. Leer el archivo de preferencias desde adb:

```
adb shell run-as com.demo.mibanco cat shared_prefs/sesion.xml
```

3. Decompilar el APK y buscar la cadena API_KEY:

```
jadx-gui app-vulnerable-debug.apk
```

Resultado: token de sesión y clave de API legibles.

run-as exige un build debug; en producción haría falta root, backup o malware.

Solo sobre apps propias, en emulador y con un servidor de pruebas

DEMO 1 · LA DEFENSA

Keystore y cero secretos en el cliente

Cifrar con Keystore

AES-GCM con una clave que no sale del Keystore. En hardware seguro (TEE, StrongBox) tampoco sale del dispositivo.

Sin secretos en el APK

Tras el login, el servidor emite un token de sesión. Ninguna clave de API vive en el cliente.

Excluir de backups

Dejar fuera de las copias de seguridad de Android los datos sensibles (MASTG-BEST-0023).

⚠ **Ojo:** EncryptedSharedPreferences y MasterKey (security-crypto) figuran como deprecated en la documentación oficial; usamos Keystore directamente.

Fuentes: Android Developers (Keystore; androidx.security.crypto) · MASTG-BEST-0023

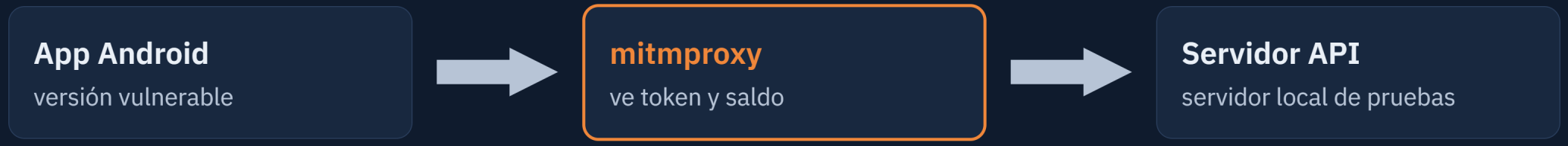
DEMO 2 · RED

Un proxy en medio lee y modifica el tráfico

Desde Android 9 el tráfico HTTP está bloqueado por defecto, y desde Android 7 las apps no confían en CA instaladas por el usuario.

Una configuración laxa (cleartext permitido o CA de usuario aceptadas) lo deshace: es el riesgo M8.

mitmproxy descifra el tráfico mientras el cliente confíe en su CA.



Fuentes: Android Developers (Network security configuration; Android 7.0) · documentación de mitmproxy

DEMO 2 · EL ATAQUE

Interceptar la sesión con mitmproxy

1. Arrancar el proxy y el emulador apuntando a él:

```
mitmweb
emulator -avd NOMBRE_AVD -http-proxy 127.0.0.1:8080
```

2. La CA de mitmproxy ya está instalada; la app vulnerable la acepta por su configuración.

3. Iniciar sesión y consultar el saldo; mirar el flujo en mitmweb.

Resultado: token y saldo visibles en claro en el proxy.

Solo con nuestro emulador y nuestro servidor de pruebas, nunca tráfico de terceros

DEMO 2 · LA DEFENSA

Solo HTTPS y pinning de clave pública

```
<network-security-config>
  <domain-config cleartextTrafficPermitted="false">
    <domain>api.mibanco.test</domain>
    <pin-set expiration="2027-06-30">
      <pin digest="SHA-256">pin-principal=</pin>
      <pin digest="SHA-256">pin-respaldo=</pin>
    </pin-set>
  </domain-config>
</network-security-config>
```

Solo HTTPS.
Sin cleartext y con confianza solo en las CA del sistema.

Pinning.
Clave pública con pin de respaldo y fecha de expiración.

Verificar.
Repetir el ataque: la conexión debe fallar.

Endurece, pero no es infalible (MASTG-KNOW-0015).

Fuentes: Android Developers (Network security configuration) · MASTG-KNOW-0015 · MASTG-TEST-0244

DEFENSA EN PROFUNDIDAD

Biometría atada a una clave del Keystore

BiometricPrompt con CryptoObject

La clave solo se puede usar después de autenticar al usuario (Cipher, Signature o Mac).

Clase 3 para datos financieros

Android recomienda biometría Clase 3 con CryptoObject en transacciones, y no ofrecer respaldo con PIN en apps sensibles.

Cambios de huellas

Por defecto, la clave se invalida si se registran nuevas biometrías en el dispositivo.

Fuentes: Android Developers (Biometric auth; Keystore; Secure user authentication)

Checklist para nuestras apps

Almacenamiento

- ✓ Guarda solo lo imprescindible
- ✓ Cifra con una clave del Keystore
- ✓ Excluye datos sensibles del backup

Red

- ✓ Solo HTTPS, con cleartext desactivado
- ✓ Pinning de tu propio backend, con pin de respaldo
- ✓ Prueba la app con un proxy MITM

Siempre

- ✓ Ningún secreto en el APK
- ✓ Revisa la app contra los controles MASVS
- ✓ Valida también en el servidor

Basado en: OWASP MASVS · OWASP MASTG · Android Developers (Security)

Límites y ética

Nada es infalible. Con el dispositivo en su poder, un atacante puede alterar la app o eludir el pinning; por eso se combinan capas y se valida en el servidor.

El pinning tiene costo operativo. El MASTG recoge la advertencia de Android Developers sobre perder conexión si cambia la CA, y recomienda pines de respaldo.

Cada app, su nivel. El MASTG lo recomienda sobre todo para el perfil L2; no es un requisito de todas las apps.

Ética. Probamos solo apps propias o con autorización por escrito, en emulador y con un servidor de pruebas.

Fuentes: MASTG-KNOW-0015 · MASTG Network Communication

Asume que el dispositivo y la red no son de confianza

Preguntas

Código de la demo: https://github.com/Ogil11/App-segura-e-insegura-.git

Referencias (1/3) · OWASP

OWASP Mobile Top 10 (proyecto)
https://owasp.org/projects/mobile-top-10

OWASP Developer Guide · Mobile Top 10
https://devguide.owasp.org/en/07-training-education/06-mobile-top-ten/

M9: Insecure Data Storage
https://owasp.org/www-project-mobile-top-10/2023-risks/m9-insecure-data-storage.html

MASVS-STORAGE
https://mas.owasp.org/MASVS/05-MASVS-STORAGE/

MASVS-NETWORK
https://mas.owasp.org/MASVS/08-MASVS-NETWORK/

MASVS-NETWORK-2 (identity pinning)
https://mas.owasp.org/MASVS/controls/MASVS-NETWORK-2/

MASTG-TEST-0287: SharedPreferences sin cifrar
https://mas.owasp.org/MASTG/tests/android/MASVS-STORAGE/MASTG-TEST-0287/

MASTG-TEST-0338: integridad del almacenamiento local
https://mas.owasp.org/MASTG/tests/android/MASVS-RESILIENCE/MASTG-TEST-0338/

Referencias (2/3) · MASTG y Android

MASTG-KNOW-0015: Certificate Pinning
https://mas.owasp.org/MASTG/knowledge/android/MASVS-NETWORK/MASTG-KNOW-0015/

MASTG-TEST-0244: Missing Certificate Pinning in Network Traffic
https://mas.owasp.org/MASTG/tests/android/MASVS-NETWORK/MASTG-TEST-0244/

MASTG · Mobile App Network Communication
https://mas.owasp.org/MASTG/0x04f-Testing-Network-Communication/

Android Developers · Network security configuration
https://developer.android.com/privacy-and-security/security-config

Android Developers · Android Keystore system
https://developer.android.com/privacy-and-security/keystore

Android Developers · Show a biometric authentication dialog
https://developer.android.com/identity/sign-in/biometric-auth

Android Developers · Secure user authentication (fraud prevention)
https://developer.android.com/security/fraud-prevention/authentication

Android Developers · androidx.security.crypto (clases deprecated)
https://developer.android.com/reference/kotlin/androidx/security/crypto/package-summary

Referencias (3/3) · Complementarias y herramientas

Android Developers · Security checklist
https://developer.android.com/privacy-and-security/security-tips

Android Developers · Android 7.0 (Network Security Config)
https://developer.android.com/about/versions/nougat/android-7.0

Android Developers · Elemento application (usesCleartextTraffic)
https://developer.android.com/guide/topics/manifest/application-element

OWASP MAS · Catálogo MASWE (novedades 2024)
https://mas.owasp.org/news/archive/2024/

mitmproxy · Certificados
https://docs.mitmproxy.org/stable/concepts/certificates/

mitmproxy · Instalar la CA en el sistema de un emulador Android
https://docs.mitmproxy.org/stable/howto/install-system-trusted-ca-android/

jadx · Decompilador de APK a Java
https://github.com/skylot/jadx